

Software Requirements Specification

Insurance Policy and Claim Management System

1. Document Overview

1.1 Project Title

Insurance Policy and Claim Management System

1.2 Project Type

Backend REST API mini project using Spring Boot.

1.3 Domain

Insurance domain.

1.4 Difficulty Level

Moderate.

1.5 Purpose of the Document

This Software Requirements Specification defines the functional, non-functional, security, data, mapping, service, repository, logging, Swagger, exception handling, and business requirements for an Insurance Policy and Claim Management System.

This document is intended to guide students or developers in building a professional backend REST API project without ambiguity.

This SRS does not provide implementation code or technical solution hints.

2. Project Overview

The Insurance Policy and Claim Management System is a REST API-based backend application for managing insurance products, policy plans, customers, policies, premium payments, and insurance claims.

The system supports three user roles:

1. Admin

- 2. Agent
- 3. Customer

Each role has clearly defined permissions based on real insurance business responsibilities.

Customers can register, create profiles, purchase insurance policies, record simulated premium payments, and raise claims. Agents can review claims and recommend claim decisions. Admins can manage insurance products, plans, users, and make final claim approval or rejection decisions.

3. Real-Life Business Scenario

An insurance company offers multiple insurance products such as health insurance, motor insurance, life insurance, and travel insurance.

Each product contains multiple plans. A customer selects a plan and purchases it as an insurance policy. The policy initially remains in a pending payment state. After successful premium payment, the policy becomes active.

Once the policy is active, the customer may raise a claim if an insured event occurs. The claim is reviewed by an agent. The agent may recommend approval or rejection, but only the admin can make the final decision.

This project simulates a simplified but realistic insurance business workflow.

4. Project Objectives

Objective ID	Objective
OBJ-001	Provide secure customer registration and user login
OBJ-002	Implement JWT-based authentication
OBJ-003	Enforce role-based authorization
OBJ-004	Manage insurance products
OBJ-005	Manage policy plans under insurance products
OBJ-006	Manage customer profiles
OBJ-007	Allow customers to purchase policies
OBJ-008	Allow agents and admins to issue policies
OBJ-009	Track simulated premium payment records
OBJ-010	Allow customers to raise insurance claims
OBJ-011	Allow agents to review and recommend claims

Objective ID	Objective
OBJ-012	Allow admins to approve or reject claims
OBJ-013	Provide centralized exception handling
OBJ-014	Maintain structured application logs
OBJ-015	Provide Swagger/OpenAPI documentation
OBJ-016	Use DTOs for API request and response communication
OBJ-017	Support pagination, sorting, and filtering for list APIs
OBJ-018	Maintain clear entity relationship mapping
OBJ-019	Prevent unauthorized access to customer-specific data

5. Assumptions

Assumption ID	Assumption
ASM-001	The project is backend-only. No frontend application is required.
ASM-002	Payment processing is simulated. No real payment gateway is required.
ASM-003	Public registration is allowed only for customers.
ASM-004	Admin and agent accounts are created or managed internally by admin.
ASM-005	Actual document upload is optional. Document references are sufficient.
ASM-006	Insurance premium calculation is fixed according to the selected plan.
ASM-007	Tax, GST, discount, renewal pricing, and dynamic premium calculation are out of scope.
ASM-008	Agent-specific claim assignment is out of scope for this mini project.
ASM-009	All agents can view claims that require review.
ASM-010	Product and plan removal should be handled through deactivation, not permanent deletion.
ASM-011	Pagination must be applied to list APIs to avoid large uncontrolled responses.

6. Scope of the System

6.1 In Scope

Scope ID	Feature
SCP-001	Customer registration and user login
SCP-002	JWT authentication
SCP-003	Role-based authorization
SCP-004	User management by admin
SCP-005	Customer profile management
SCP-006	Insurance product management
SCP-007	Policy plan management
SCP-008	Policy purchase and issuance
SCP-009	Simulated premium payment management
SCP-010	Claim submission
SCP-011	Claim review by agent
SCP-012	Final claim decision by admin
SCP-013	Claim status history
SCP-014	DTO-based request and response handling
SCP-015	Centralized exception handling
SCP-016	Application logging
SCP-017	Swagger/OpenAPI documentation
SCP-018	Pagination, sorting, and filtering
SCP-019	Entity relationship mapping

6.2 Out of Scope

Out-of-Scope ID	Excluded Feature
OOS-001	Real payment gateway integration
OOS-002	Real KYC verification
OOS-003	Email or SMS notification

Out-of-Scope ID	Excluded Feature
OOS-004	Actual cloud-based document storage
OOS-005	AI-based fraud detection
OOS-006	Frontend application
OOS-007	Microservices architecture
OOS-008	Docker or Kubernetes deployment
OOS-009	Real insurance underwriting engine
OOS-010	Policy renewal automation
OOS-011	Refund processing
OOS-012	Claim settlement bank transfer

7. User Roles and Responsibilities

7.1 Admin

Admin is responsible for overall system administration.

Admin can:

- Manage insurance products.
- Manage policy plans.
- View all users.
- Activate or deactivate users.
- Create and manage agent accounts.
- View all customers.
- View all policies.
- View all premium payments.
- View all claims.
- Make final claim approval or rejection.
- View claim status history.
- Access system-level summary data.

Admin cannot:

- Register publicly as admin.
 - Raise claims as a customer.
 - Bypass policy and claim business rules.
-

7.2 Agent

Agent represents an insurance company employee.

Agent can:

- View customer details.
- View customer policies.
- Issue policies to customers.
- View premium payment status.
- Review submitted claims.
- Add claim review remarks.
- Recommend claim approval.
- Recommend claim rejection.
- View claim status history.

Agent cannot:

- Create insurance products.
 - Create policy plans.
 - Make final claim approval.
 - Make final claim rejection.
 - Access user management features.
 - Register publicly as agent.
-

7.3 Customer

Customer is the end user purchasing insurance.

Customer can:

- Register publicly.
- Login securely.
- Create own profile.
- Update own profile.
- View available insurance products.
- View available policy plans.
- Purchase policies.
- View own policies.
- Record simulated premium payments for own policies.
- Raise claims against own active policies.
- View own claims.
- View own payment history.

Customer cannot:

- View another customer's profile.
- View another customer's policies.
- View another customer's payments.
- View another customer's claims.
- Create insurance products.
- Create policy plans.
- Review claims.
- Approve or reject claims.
- Register as admin or agent.

8. System Modules

Module ID	Module Name	Description
MOD-001	Authentication and Authorization Module	Handles registration, login, JWT validation, and role-based access
MOD-002	User Management Module	Handles user account status and internal user management
MOD-003	Customer Management Module	Handles customer profile creation and updates
MOD-004	Insurance Product Module	Handles insurance product management
MOD-005	Policy Plan Module	Handles policy plan management
MOD-006	Policy Module	Handles policy purchase, issuance, status, and cancellation
MOD-007	Premium Payment Module	Handles simulated premium payment records
MOD-008	Claim Module	Handles claim submission, review, recommendation, and final decision
MOD-009	Claim Status History Module	Maintains claim status change history
MOD-010	Exception Handling Module	Handles consistent error responses
MOD-011	Logging Module	Maintains structured application logs
MOD-012	Swagger Documentation Module	Documents APIs and security requirements

9. Data Model Requirements

The system must maintain the following business entities.

9.1 User

The User entity represents account and login information.

Required Data Fields

Field	Description
User ID	Unique system identifier
Full Name	Name of the user
Email	Unique login email
Password	Secured password
Mobile Number	Contact number
Role	Admin, Agent, or Customer
Active Status	Indicates whether the account is active
Created Date	Account creation date and time
Updated Date	Last account update date and time

Business Rules

Rule ID	Rule
USR-BR-001	Email must be unique.
USR-BR-002	Password must be stored securely.
USR-BR-003	Public registration must create only customer accounts.
USR-BR-004	Admin and agent accounts must be controlled internally by admin.
USR-BR-005	Inactive users must not be allowed to login.
USR-BR-006	A user must have exactly one role.

9.2 Customer

The Customer entity represents customer profile information.

Required Data Fields

Field	Description
Customer ID	Unique customer identifier
Linked User	User account associated with the customer
Date of Birth	Customer's date of birth
Address	Residential address
City	City of residence
State	State of residence
PIN Code	Postal code
Nominee Name	Name of nominee
Nominee Relation	Relationship with nominee
Created Date	Profile creation date and time
Updated Date	Last profile update date and time

Business Rules

Rule ID	Rule
CUS-BR-001	Only users with customer role can have a customer profile.
CUS-BR-002	One customer user can have only one customer profile.
CUS-BR-003	Customer profile must be completed before policy purchase.
CUS-BR-004	A customer can update only their own profile.
CUS-BR-005	Admin and agent can view customer details for business purposes.

9.3 Insurance Product

The Insurance Product entity represents the main insurance category.

Required Data Fields

Field	Description
Product ID	Unique product identifier
Product Name	Name of the insurance product

Field	Description
Product Type	Health, Motor, Life, or Travel
Description	Product description
Active Status	Indicates whether product is available
Created Date	Product creation date and time
Updated Date	Last product update date and time

Business Rules

Rule ID	Rule
PRD-BR-001	Product name must be unique.
PRD-BR-002	Only active products should be available for new plans and purchases.
PRD-BR-003	Products linked to plans or policies should not be permanently deleted.
PRD-BR-004	Products should be deactivated when no longer offered.

9.4 Policy Plan

The Policy Plan entity represents a purchasable insurance plan under an insurance product.

Required Data Fields

Field	Description
Plan ID	Unique plan identifier
Insurance Product	Associated insurance product
Plan Name	Name of the plan
Coverage Amount	Maximum coverage offered by the plan
Premium Amount	Required premium amount
Premium Type	One-time or annual premium
Duration	Policy duration in years
Terms and Conditions	Key terms of the plan
Active Status	Indicates whether plan is available
Created Date	Plan creation date and time

Field	Description
Updated Date	Last plan update date and time

Business Rules

Rule ID	Rule
PLN-BR-001	A plan must belong to one insurance product.
PLN-BR-002	Coverage amount must be greater than zero.
PLN-BR-003	Premium amount must be greater than zero.
PLN-BR-004	Coverage amount must be higher than premium amount.
PLN-BR-005	Only active plans can be purchased.
PLN-BR-006	Plans linked to active policies should not be permanently deleted.
PLN-BR-007	Plan premium should be treated as the required initial premium for policy activation.

9.5 Policy

The Policy entity represents an insurance policy purchased by or issued to a customer.

Required Data Fields

Field	Description
Policy ID	Unique system identifier
Policy Number	Unique business policy number
Customer	Associated customer
Policy Plan	Selected policy plan
Start Date	Policy start date
End Date	Policy end date
Policy Status	Pending Payment, Active, Expired, or Cancelled
Total Premium Paid	Total recorded successful premium amount
Created Date	Policy creation date and time
Updated Date	Last policy update date and time

Business Rules

Rule ID	Rule
POL-BR-001	Every policy must belong to one customer.
POL-BR-002	Every policy must be linked to one active policy plan.
POL-BR-003	Policy number must be unique.
POL-BR-004	Newly created policies must be marked as Pending Payment.
POL-BR-005	A policy becomes Active after successful payment of the required premium.
POL-BR-006	A policy is considered Expired when the current date is after the policy end date.
POL-BR-007	Cancelled policies cannot be reactivated in this mini project.
POL-BR-008	Claims can be raised only against Active policies.
POL-BR-009	Customers can view only their own policies.
POL-BR-010	Agents and admins can view customer policies.

9.6 Premium Payment

The Premium Payment entity represents a simulated payment record against a policy.

Required Data Fields

Field	Description
Payment ID	Unique payment identifier
Policy	Associated policy
Amount	Payment amount
Payment Date	Date and time of payment record
Payment Mode	UPI, Card, Net Banking, or Cash
Transaction Reference	Unique transaction reference
Payment Status	Success, Failed, or Pending
Created Date	Payment record creation date and time

Business Rules

Rule ID	Rule
PAY-BR-001	Payment must be linked to an existing policy.
PAY-BR-002	Payment amount must be greater than zero.
PAY-BR-003	Transaction reference must be unique.
PAY-BR-004	Successful payments should increase the total premium paid for the policy.
PAY-BR-005	Failed payments must not activate a policy.
PAY-BR-006	Pending payments must not activate a policy.
PAY-BR-007	First successful payment equal to or greater than the required premium should activate the policy.
PAY-BR-008	Payment processing is simulated and does not verify with any external gateway.
PAY-BR-009	Customers can view payment records only for their own policies.

9.7 Claim

The Claim entity represents an insurance claim submitted by a customer.

Required Data Fields

Field	Description
Claim ID	Unique claim identifier
Claim Number	Unique business claim number
Policy	Associated policy
Claim Amount	Amount requested by customer
Claim Reason	Reason for claim
Incident Date	Date of incident

Field	Description
Claim Status	Current claim status
Agent Remarks	Remarks added by agent
Admin Remarks	Final remarks added by admin
Created Date	Claim submission date and time
Updated Date	Last claim update date and time

Business Rules

Rule ID	Rule
CLM-BR-001	Claim must be linked to an existing active policy.
CLM-BR-002	Claim number must be unique.
CLM-BR-003	Claim amount must be greater than zero.
CLM-BR-004	Claim amount must not exceed the policy coverage amount.
CLM-BR-005	Incident date must not be a future date.
CLM-BR-006	Customer can raise claims only for their own policies.
CLM-BR-007	Agent can review and recommend claims.
CLM-BR-008	Admin can make the final claim decision.
CLM-BR-009	Approved and rejected claims cannot be modified again.
CLM-BR-010	Claims cannot be raised against expired, cancelled, or pending-payment policies.

9.8 Claim Document

The Claim Document entity stores document references submitted for claim verification.

Required Data Fields

Field	Description
Document ID	Unique document identifier
Claim	Associated claim
Document Name	Name of the submitted document
Document Type	Type of document

Field	Description
Document Reference	File name, URL, or reference text
Uploaded Date	Date and time of document reference submission

Business Rules

Rule ID	Rule
DOC-BR-001	Claim should have at least one supporting document reference.
DOC-BR-002	Actual file upload is optional for this mini project.
DOC-BR-003	Document reference may be stored as file name, URL, or text reference.
DOC-BR-004	Claim documents must be linked to an existing claim.

9.9 Claim Status History

The Claim Status History entity represents the status movement of a claim.

Required Data Fields

Field	Description
History ID	Unique history identifier
Claim	Associated claim
Previous Status	Claim status before update
New Status	Claim status after update
Remarks	Remarks added during status update
Updated By	User who changed the status
Updated Date	Date and time of status update

Business Rules

Rule ID	Rule
HIS-BR-001	Every claim status change must be recorded.
HIS-BR-002	History records should not be modified once created.
HIS-BR-003	History should show who changed the claim status and when.

Rule ID	Rule
HIS-BR-004	Claim history must be available for admin and agent review.

10. Entity Relationship Mapping

The following entity relationships must be maintained.

Mapping ID	Relationship	Type	Description
MAP-001	User to Customer	One-to-One	One customer user can have one customer profile
MAP-002	Insurance Product to Policy Plan	One-to-Many	One insurance product can have multiple policy plans
MAP-003	Policy Plan to Policy	One-to-Many	One policy plan can be purchased by multiple customers as separate policies
MAP-004	Customer to Policy	One-to-Many	One customer can have multiple policies
MAP-005	Policy to Premium Payment	One-to-Many	One policy can have multiple premium payment records
MAP-006	Policy to Claim	One-to-Many	One policy can have multiple claims
MAP-007	Claim to Claim Document	One-to-Many	One claim can have multiple document references
MAP-008	Claim to Claim Status History	One-to-Many	One claim can have multiple status history records
MAP-009	User to Claim Status History	One-to-Many	One user can perform multiple claim status updates

Mapping Rules

Rule ID	Rule
MAP-BR-001	A customer profile must not exist without a linked user account.
MAP-BR-002	A policy plan must not exist without an insurance product.

Rule ID	Rule
MAP-BR-003	A policy must not exist without a customer and policy plan.
MAP-BR-004	A premium payment must not exist without a policy.
MAP-BR-005	A claim must not exist without a policy.
MAP-BR-006	A claim document must not exist without a claim.
MAP-BR-007	Claim status history must not exist without a claim.
MAP-BR-008	Products and plans linked to business records must be deactivated instead of permanently deleted.
MAP-BR-009	Policies, payments, claims, and claim histories must not be hard deleted.

11. DTO Requirements

The system must use DTOs for all API requests and responses.

Entities must not be directly exposed to API consumers.

11.1 General DTO Rules

Rule ID	Rule
DTO-RUL-001	Request DTOs should contain only fields required from the client.
DTO-RUL-002	Response DTOs should contain only fields required by the client.
DTO-RUL-003	Internal database relationships must not be exposed directly.
DTO-RUL-004	Sensitive fields must not be included in responses.
DTO-RUL-005	Passwords must never be returned in any response.
DTO-RUL-006	JWT tokens should be returned only after successful login.

11.2 Authentication DTOs

Register Request

Must contain:

- Full name
- Email
- Password
- Mobile number

Role should not be accepted during public customer registration.

Login Request

Must contain:

- Email
- Password

Login Response

Must contain:

- JWT token
 - Token type
 - User email
 - User role
 - Token expiry information
-

11.3 User DTOs

User Response

Must contain:

- User ID
- Full name
- Email
- Mobile number
- Role
- Active status
- Created date

User Status Update Request

Must contain:

- Active status
 - Reason or remarks
-

11.4 Customer DTOs

Customer Request

Must contain:

- Date of birth
- Address
- City
- State
- PIN code
- Nominee name
- Nominee relation

Customer Response

Must contain:

- Customer ID
 - Full name
 - Email
 - Mobile number
 - Date of birth
 - Address
 - City
 - State
 - PIN code
 - Nominee name
 - Nominee relation
-

11.5 Insurance Product DTOs

Product Request

Must contain:

- Product name

- Product type
- Description
- Active status

Product Response

Must contain:

- Product ID
 - Product name
 - Product type
 - Description
 - Active status
 - Created date
 - Updated date
-

11.6 Policy Plan DTOs

Plan Request

Must contain:

- Product reference
- Plan name
- Coverage amount
- Premium amount
- Premium type
- Duration
- Terms and conditions
- Active status

Plan Response

Must contain:

- Plan ID
 - Product name
 - Product type
 - Plan name
 - Coverage amount
 - Premium amount
 - Premium type
 - Duration
 - Terms and conditions
 - Active status
-

11.7 Policy DTOs

Customer Policy Purchase Request

Must contain:

- Plan reference
- Start date

Customer reference must be derived from the authenticated customer account.

Agent or Admin Policy Issue Request

Must contain:

- Customer reference
- Plan reference
- Start date

Policy Response

Must contain:

- Policy ID
 - Policy number
 - Customer name
 - Plan name
 - Product type
 - Coverage amount
 - Premium amount
 - Premium type
 - Start date
 - End date
 - Policy status
 - Total premium paid
-

11.8 Premium Payment DTOs

Payment Request

Must contain:

- Policy reference
- Amount
- Payment mode
- Transaction reference

- Payment status

Payment Response

Must contain:

- Payment ID
 - Policy number
 - Amount
 - Payment date
 - Payment mode
 - Transaction reference
 - Payment status
-

11.9 Claim DTOs

Claim Request

Must contain:

- Policy reference
- Claim amount
- Claim reason
- Incident date
- Supporting document details

Claim Response

Must contain:

- Claim ID
- Claim number
- Policy number
- Customer name
- Claim amount
- Claim reason
- Incident date
- Claim status
- Agent remarks
- Admin remarks
- Created date
- Updated date

Claim Review Request

Must contain:

- Recommended status
- Remarks

Claim Final Decision Request

Must contain:

- Final decision status
- Remarks

11.10 Common Response DTOs

Every successful response should follow a consistent response structure containing:

- Success status
- Message
- Data
- Timestamp

Every error response should follow a consistent error structure containing:

- Timestamp
- Status code
- Error type
- Message
- Request path

Every paginated response should follow a consistent pagination response structure containing:

- Records
 - Current page number
 - Page size
 - Total records
 - Total pages
 - Last page indicator
 - Sorting information, where applicable
-

12. Functional Requirements

12.1 Authentication and Authorization

Requirement ID	Requirement
FR-AUTH-001	The system shall allow customers to register publicly.
FR-AUTH-002	The system shall not allow public registration as admin or agent.
FR-AUTH-003	The system shall allow registered active users to login.
FR-AUTH-004	The system shall generate a JWT token after successful login.
FR-AUTH-005	The system shall validate JWT tokens for protected APIs.
FR-AUTH-006	The system shall reject invalid or expired JWT tokens.
FR-AUTH-007	The system shall restrict API access based on user role.
FR-AUTH-008	The system shall prevent inactive users from logging in.
FR-AUTH-009	The system shall secure user passwords before storage.

12.2 User Management

Requirement ID	Requirement
FR-USER-001	The system shall allow admin to view all users.
FR-USER-002	The system shall allow admin to activate users.
FR-USER-003	The system shall allow admin to deactivate users.
FR-USER-004	The system shall allow admin to create agent accounts.
FR-USER-005	The system shall prevent duplicate email registration.
FR-USER-006	The system shall maintain created and updated dates for users.
FR-USER-007	The system shall support paginated, sorted, and filtered user listing for admin.

12.3 Customer Management

Requirement ID	Requirement
FR-CUS-001	The system shall allow customers to create their own profile.

Requirement ID	Requirement
FR-CUS-002	The system shall allow customers to update their own profile.
FR-CUS-003	The system shall allow customers to view their own profile.
FR-CUS-004	The system shall allow admin and agent to view customer details.
FR-CUS-005	The system shall prevent customers from accessing another customer's profile.
FR-CUS-006	The system shall support paginated, sorted, and filtered customer listing for admin and agent.

12.4 Insurance Product Management

Requirement ID	Requirement
FR-PRD-001	The system shall allow admin to create insurance products.
FR-PRD-002	The system shall allow admin to update insurance products.
FR-PRD-003	The system shall allow admin to deactivate insurance products.
FR-PRD-004	The system shall allow users to view active insurance products.
FR-PRD-005	The system shall prevent duplicate product names.
FR-PRD-006	The system shall prevent inactive products from being used for new plans.
FR-PRD-007	The system shall support paginated, sorted, and filtered product listing.

12.5 Policy Plan Management

Requirement ID	Requirement
FR-PLN-001	The system shall allow admin to create policy plans.
FR-PLN-002	The system shall allow admin to update policy plans.
FR-PLN-003	The system shall allow admin to deactivate policy plans.
FR-PLN-004	The system shall allow users to view active plans.
FR-PLN-005	The system shall allow users to view plans under a selected insurance product.
FR-PLN-006	The system shall prevent purchase from inactive plans.
FR-PLN-007	The system shall validate coverage amount, premium amount, duration, and terms.

Requirement ID	Requirement
FR-PLN-008	The system shall support paginated, sorted, and filtered plan listing.

12.6 Policy Management

Requirement ID	Requirement
FR-POL-001	The system shall allow customers to purchase policies from active plans.
FR-POL-002	The system shall allow agents and admins to issue policies to customers.
FR-POL-003	The system shall generate a unique policy number for every policy.
FR-POL-004	The system shall create new policies with Pending Payment status.
FR-POL-005	The system shall activate a policy after successful premium payment.
FR-POL-006	The system shall allow customers to view only their own policies.
FR-POL-007	The system shall allow agents and admins to view customer policies.
FR-POL-008	The system shall allow agents and admins to cancel policies.
FR-POL-009	The system shall prevent claims on expired, cancelled, or pending-payment policies.
FR-POL-010	The system shall consider a policy expired when the current date is after its end date.
FR-POL-011	The system shall support paginated, sorted, and filtered policy listing for admin and agent.

12.7 Premium Payment Management

Requirement ID	Requirement
FR-PAY-001	The system shall allow customers to record simulated premium payments for their own policies.
FR-PAY-002	The system shall allow agents to record simulated payments on behalf of customers.
FR-PAY-003	The system shall validate payment amount.
FR-PAY-004	The system shall prevent duplicate transaction references.
FR-PAY-005	The system shall update total premium paid after successful payment.

Requirement ID	Requirement
FR-PAY-006	The system shall activate policy after successful required payment.
FR-PAY-007	The system shall prevent failed or pending payments from activating policies.
FR-PAY-008	The system shall allow customers to view payment history only for their own policies.
FR-PAY-009	The system shall allow agents and admins to view payment records.
FR-PAY-010	The system shall support paginated, sorted, and filtered payment listing for admin and agent.

12.8 Claim Management

Requirement ID	Requirement
FR-CLM-001	The system shall allow customers to raise claims against their own active policies.
FR-CLM-002	The system shall generate a unique claim number for every claim.
FR-CLM-003	The system shall require claim amount, reason, incident date, and document details.
FR-CLM-004	The system shall prevent claim amount from exceeding policy coverage.
FR-CLM-005	The system shall allow customers to view only their own claims.
FR-CLM-006	The system shall allow agents to review submitted claims.
FR-CLM-007	The system shall allow agents to recommend claim approval or rejection.
FR-CLM-008	The system shall allow admins to approve or reject claims finally.
FR-CLM-009	The system shall prevent modification of approved or rejected claims.
FR-CLM-010	The system shall maintain claim status history for every status change.
FR-CLM-011	The system shall support paginated, sorted, and filtered claim listing for admin and agent.

13. Role-Based Access Matrix

Feature	Admin	Agent	Customer
Public registration	No	No	Yes
Login	Yes	Yes	Yes

Feature	Admin	Agent	Customer
Create agent account	Yes	No	No
View users	Yes	No	No
Activate/deactivate users	Yes	No	No
Create product	Yes	No	No
Update product	Yes	No	No
Deactivate product	Yes	No	No
View active products	Yes	Yes	Yes
Create policy plan	Yes	No	No
Update policy plan	Yes	No	No
Deactivate policy plan	Yes	No	No
View active plans	Yes	Yes	Yes
Create own customer profile	No	No	Yes
View all customers	Yes	Yes	No
View own profile	No	No	Yes
Purchase own policy	No	No	Yes
Issue policy to customer	Yes	Yes	No
View all policies	Yes	Yes	No
View own policies	No	No	Yes
Cancel policy	Yes	Yes	No
Record own payment	No	No	Yes
Record payment for customer	Yes	Yes	No
View all payments	Yes	Yes	No
View own payments	No	No	Yes
Raise claim	No	No	Yes
Review claim	No	Yes	No
Recommend claim decision	No	Yes	No
Final claim decision	Yes	No	No
View all claims	Yes	Yes	No

Feature	Admin	Agent	Customer
View own claims	No	No	Yes
View claim status history	Yes	Yes	Own claims only

14. Policy Lifecycle

Stage	Status	Responsible Action
Policy created	Pending Payment	Customer purchases policy or admin/agent issues policy
Required premium paid successfully	Active	Payment is recorded as successful
Policy end date passed	Expired	System identifies policy as expired based on end date
Policy cancelled	Cancelled	Admin or agent cancels policy

Policy Lifecycle Rules

Rule ID	Rule
PLC-RUL-001	New policies must always begin with Pending Payment status.
PLC-RUL-002	Only successful required payment can activate a policy.
PLC-RUL-003	Failed payment cannot activate a policy.
PLC-RUL-004	Pending payment cannot activate a policy.
PLC-RUL-005	Expired policies cannot accept new claims.
PLC-RUL-006	Cancelled policies cannot accept new claims.
PLC-RUL-007	Cancelled policies cannot be reactivated in this mini project.

15. Claim Lifecycle

Stage	Status	Responsible Role
Claim submitted	Submitted	Customer
Claim taken for review	Under Review	Agent

Stage	Status	Responsible Role
Agent recommends approval	Recommended for Approval	Agent
Agent recommends rejection	Recommended for Rejection	Agent
Claim approved finally	Approved	Admin
Claim rejected finally	Rejected	Admin

Claim Lifecycle Rules

Rule ID	Rule
CLC-RUL-001	A claim must start with Submitted status.
CLC-RUL-002	Only an agent can move a claim to Under Review.
CLC-RUL-003	Only an agent can recommend approval or rejection.
CLC-RUL-004	Only an admin can approve or reject a claim finally.
CLC-RUL-005	Approved claims cannot be modified.
CLC-RUL-006	Rejected claims cannot be modified.
CLC-RUL-007	Every status change must be recorded in claim status history.
CLC-RUL-008	Invalid status movements must be rejected.

16. Payment Handling Rules

The project will use simulated payment records only.

Rule ID	Rule
PMT-RUL-001	No external payment gateway is required.
PMT-RUL-002	Payment status should be recorded as Success, Failed, or Pending.
PMT-RUL-003	Only successful payments should affect total premium paid.
PMT-RUL-004	Failed payments should be stored for record purposes but must not activate the policy.
PMT-RUL-005	Pending payments should not activate the policy.

Rule ID	Rule
PMT-RUL-006	Transaction reference must be unique.
PMT-RUL-007	The first successful payment equal to or greater than the required premium activates the policy.
PMT-RUL-008	Partial payment handling is out of scope unless explicitly added as an enhancement.

17. Validation Requirements

17.1 User Validation

Field	Rule
Full Name	Required
Email	Required, valid, unique
Password	Required and must meet minimum security expectations
Mobile Number	Required and valid
Role	Required and valid for internal user creation

17.2 Customer Validation

Field	Rule
Date of Birth	Required and must be a past date
Address	Required
City	Required
State	Required
PIN Code	Required and valid
Nominee Name	Required
Nominee Relation	Required

17.3 Product Validation

Field	Rule
Product Name	Required and unique
Product Type	Required and valid
Description	Required
Active Status	Required

17.4 Plan Validation

Field	Rule
Product Reference	Required and must refer to an active product
Plan Name	Required
Coverage Amount	Must be greater than zero
Premium Amount	Must be greater than zero
Premium Type	Required
Duration	Must be greater than zero
Terms and Conditions	Required

17.5 Policy Validation

Field	Rule
Customer Reference	Required for admin or agent policy issuance
Plan Reference	Required and must refer to an active plan
Start Date	Required and valid
End Date	Must be derived from start date and plan duration
Policy Number	Must be unique

17.6 Payment Validation

Field	Rule
Policy Reference	Required and must exist
Amount	Must be greater than zero
Payment Mode	Required and valid
Transaction Reference	Required and unique
Payment Status	Required and valid

17.7 Claim Validation

Field	Rule
Policy Reference	Required and must belong to the customer
Policy Status	Must be Active
Claim Amount	Must be greater than zero
Claim Amount	Must not exceed policy coverage
Claim Reason	Required
Incident Date	Required and cannot be future date
Supporting Documents	At least one document reference required

18. Exception Handling Requirements

The system must have centralized exception handling and consistent error responses.

18.1 Required Exception Scenarios

Exception Scenario ID	Scenario
EXC-001	Resource not found
EXC-002	Duplicate email
EXC-003	Duplicate product name
EXC-004	Duplicate transaction reference

Exception Scenario ID	Scenario
EXC-005	Invalid login credentials
EXC-006	Inactive user login attempt
EXC-007	Unauthorized access
EXC-008	Forbidden role access
EXC-009	Invalid policy status
EXC-010	Invalid claim status
EXC-011	Claim amount exceeding coverage
EXC-012	Validation failure
EXC-013	Invalid JWT token
EXC-014	Expired JWT token
EXC-015	Attempt to access another customer's data
EXC-016	Attempt to modify approved or rejected claim
EXC-017	Invalid pagination request
EXC-018	Invalid sorting field
EXC-019	Unexpected internal server error

18.2 Standard Error Response

Every error response must contain:

Field	Description
Timestamp	Time of error occurrence
Status Code	HTTP response status code
Error Type	Error category
Message	Clear user-readable message
Path	API path where error occurred

18.3 HTTP Status Expectations

Scenario	Expected Status
Successful fetch	200 OK
Successful creation	201 Created
Successful update	200 OK
Successful deactivation	200 OK or 204 No Content
Validation failure	400 Bad Request
Invalid login	401 Unauthorized
Missing or invalid token	401 Unauthorized
Access denied due to role	403 Forbidden
Resource not found	404 Not Found
Duplicate resource	409 Conflict
Invalid pagination or sorting request	400 Bad Request
Unexpected server failure	500 Internal Server Error

19. Repository Layer Requirements

The repository layer must be responsible only for data access.

19.1 Repository Responsibilities

The system must provide data access support for:

- User records
- Customer records
- Insurance product records
- Policy plan records
- Policy records
- Premium payment records
- Claim records
- Claim document records
- Claim status history records

19.2 Repository Rules

Rule ID	Rule
REP-RUL-001	Repository layer must not contain business logic.
REP-RUL-002	Repository layer must support saving records.
REP-RUL-003	Repository layer must support updating records.
REP-RUL-004	Repository layer must support fetching records by unique identifiers.
REP-RUL-005	Repository layer must support checking duplicate records where required.
REP-RUL-006	Repository layer must support filtering, sorting, and pagination where required.
REP-RUL-007	Repository layer must support business identifier lookups such as policy number and claim number.

20. Service Layer Requirements

The service layer must contain business logic and rule enforcement.

20.1 Required Service Areas

The system must provide service support for:

- Authentication
- User management
- Customer management
- Insurance product management
- Policy plan management
- Policy management
- Premium payment management
- Claim management
- Claim status history management

20.2 Service Layer Rules

Rule ID	Rule
SRV-RUL-001	Service layer must enforce business rules.
SRV-RUL-002	Service layer must validate role-specific operations.
SRV-RUL-003	Service layer must coordinate data access through repository layer.
SRV-RUL-004	Service layer must prepare response data using DTOs.
SRV-RUL-005	Service layer must not expose entities directly to controllers.
SRV-RUL-006	Service layer must throw meaningful business exceptions.
SRV-RUL-007	Service layer must maintain policy lifecycle rules.
SRV-RUL-008	Service layer must maintain claim lifecycle rules.
SRV-RUL-009	Service layer must record important business logs.
SRV-RUL-010	Service layer must ensure customers cannot access other customers' data.
SRV-RUL-011	Service layer must validate pagination, sorting, and filtering requests.

21. Controller Layer Requirements

The controller layer must expose REST APIs.

21.1 Controller Responsibilities

Rule ID	Rule
CON-RUL-001	Controllers must accept API requests.
CON-RUL-002	Controllers must validate request payloads.
CON-RUL-003	Controllers must call the appropriate service layer.
CON-RUL-004	Controllers must return structured responses.
CON-RUL-005	Controllers must return proper HTTP status codes.

Rule ID	Rule
CON-RUL-006	Controllers must not contain business logic.
CON-RUL-007	Controllers must be documented in Swagger.
CON-RUL-008	Controllers handling list APIs must support pagination, sorting, and filtering parameters where applicable.

22. API Capability Requirements

The system should expose REST API capabilities for the following areas.

API Group	Required Capabilities
Authentication APIs	Register customer, login user
User APIs	View users, create agent, activate user, deactivate user
Customer APIs	Create profile, update profile, view own profile, view customer details, list customers
Product APIs	Create product, update product, view products, deactivate product
Plan APIs	Create plan, update plan, view plans, deactivate plan
Policy APIs	Purchase policy, issue policy, view policy, list policies, cancel policy
Payment APIs	Record payment, view payment history, list payments
Claim APIs	Raise claim, review claim, recommend claim decision, approve claim, reject claim, view claims
Claim History APIs	View claim status history

The exact endpoint naming should be RESTful, consistent, and documented in Swagger.

23. Security Requirements

The system must implement JWT-based authentication and role-based authorization.

23.1 Authentication Requirements

Requirement ID	Requirement
SEC-AUTH-001	The system shall authenticate users using email and password.
SEC-AUTH-002	The system shall generate a JWT token after successful login.
SEC-AUTH-003	The system shall require JWT token for protected APIs.
SEC-AUTH-004	The system shall reject missing, invalid, or expired tokens.
SEC-AUTH-005	The system shall prevent inactive users from logging in.
SEC-AUTH-006	The system shall store passwords securely.
SEC-AUTH-007	The system shall not expose password data in any API response.

23.2 Authorization Requirements

Requirement ID	Requirement
SEC-AUTHZ-001	The system shall allow access based on user role.
SEC-AUTHZ-002	The system shall restrict admin-only operations.
SEC-AUTHZ-003	The system shall restrict agent-only operations.
SEC-AUTHZ-004	The system shall restrict customer-only operations.
SEC-AUTHZ-005	The system shall prevent customers from accessing another customer's data.
SEC-AUTHZ-006	The system shall return proper error responses for unauthorized access.
SEC-AUTHZ-007	The system shall return proper error responses for forbidden access.

23.3 JWT Token Requirements

JWT token must include only necessary identity and authorization information.

It may include:

- User identity
- Email
- Role
- Token issue time
- Token expiry time

JWT token must not include:

- Password
 - Sensitive customer profile data
 - Payment details
 - Claim details
 - Confidential document details
-

24. Swagger Documentation Requirements

The system must include Swagger/OpenAPI documentation.

24.1 Swagger Must Document

Requirement ID	Requirement
SWG-001	API title
SWG-002	API description
SWG-003	API version
SWG-004	Authentication requirements
SWG-005	JWT bearer token usage
SWG-006	API groups by module
SWG-007	Request structures
SWG-008	Response structures
SWG-009	Error responses
SWG-010	Role-based access information
SWG-011	Pagination, sorting, and filtering parameters for list APIs

Swagger should be accessible during development and testing.

25. Logging Requirements

The system must maintain structured application logs.

25.1 Events to Log

Log ID	Event
LOG-001	User registration
LOG-002	Login success
LOG-003	Login failure
LOG-004	Product creation or update
LOG-005	Plan creation or update
LOG-006	Policy purchase
LOG-007	Policy issuance
LOG-008	Payment record creation
LOG-009	Claim submission
LOG-010	Claim review
LOG-011	Claim recommendation
LOG-012	Final claim approval
LOG-013	Final claim rejection
LOG-014	Security failure
LOG-015	Business rule violation
LOG-016	Unexpected system error
LOG-017	Invalid pagination or sorting request

25.2 Logging Rules

Rule ID	Rule
LOG-RUL-001	Passwords must never be logged.
LOG-RUL-002	JWT tokens must never be logged.
LOG-RUL-003	Sensitive customer data should not be logged unnecessarily.
LOG-RUL-004	Successful business operations should be logged at an appropriate level.
LOG-RUL-005	Invalid business actions should be logged as warnings.
LOG-RUL-006	Unexpected failures should be logged as errors.

Rule ID	Rule
LOG-RUL-007	Logs should be meaningful enough for debugging and audit review.

26. Pagination, Sorting, and Filtering Requirements

The system must support pagination, sorting, and filtering for list APIs.

This section is mandatory to prevent large uncontrolled API responses and to keep list APIs clean, consistent, and professional.

26.1 APIs Requiring Pagination

Pagination must be available for the following list APIs:

Module	Pagination Requirement
Users	Paginated user listing
Customers	Paginated customer listing
Products	Paginated product listing
Plans	Paginated plan listing
Policies	Paginated policy listing
Payments	Paginated payment listing
Claims	Paginated claim listing
Claim Status History	Paginated history listing, where applicable

26.2 Default Pagination Rules

Rule ID	Rule
PAG-RUL-001	All list APIs must support default pagination values when the client does not provide pagination inputs.
PAG-RUL-002	Default page number should be treated as the first page.

Rule ID	Rule
PAG-RUL-003	Default page size should be limited to a reasonable number of records.
PAG-RUL-004	The system must not return unlimited records for list APIs.
PAG-RUL-005	The system must define a maximum allowed page size to prevent very large responses.
PAG-RUL-006	Requests with invalid page number or page size must be rejected with a proper validation error.
PAG-RUL-007	Negative page numbers must not be accepted.
PAG-RUL-008	Page size must be greater than zero.
PAG-RUL-009	Page size exceeding the maximum allowed limit must be rejected or adjusted according to system rules.
PAG-RUL-010	Pagination behavior must be consistent across all list APIs.

26.3 Recommended Pagination Values

Pagination Item	Recommended Value
Default Page Number	First page
Default Page Size	10 records
Maximum Page Size	100 records
Default Sort Field	Created date
Default Sort Direction	Descending

These values should be treated as project-level standards unless the project evaluator provides different requirements.

26.4 Sorting Requirements

Rule ID	Rule
SRT-RUL-001	List APIs should support sorting where applicable.

Rule ID	Rule
SRT-RUL-002	Default sorting should be based on created date in descending order.
SRT-RUL-003	Sorting should be allowed only on approved fields.
SRT-RUL-004	Invalid sorting fields must be rejected with a clear error message.
SRT-RUL-005	Sorting direction should support ascending and descending order.

26.5 Filtering Requirements

Module	Required Filters
Users	Role, active status
Products	Product type, active status
Plans	Product, active status
Policies	Policy status, customer
Payments	Policy, payment status
Claims	Claim status, customer
Claim History	Claim, updated by, status

26.6 Paginated Response Requirements

Every paginated response should contain:

Field	Description
Records	List of returned records
Current Page	Current page number
Page Size	Number of records requested per page
Total Records	Total matching records
Total Pages	Total available pages
Last Page Indicator	Whether the current page is the last page
Sort Field	Field used for sorting, where applicable
Sort Direction	Ascending or descending, where applicable

26.7 Pagination Acceptance Rules

Rule ID	Rule
PAG-AC-001	List APIs must not return all records by default.
PAG-AC-002	If pagination inputs are missing, default pagination must be applied.
PAG-AC-003	If invalid pagination inputs are supplied, the system must return a structured validation error.
PAG-AC-004	Pagination metadata must be present in list API responses.
PAG-AC-005	Filtering and sorting should work together with pagination.

27. Business Identifier Rules

Identifier	Rule
User ID	Internal unique identifier
Customer ID	Internal unique identifier
Product ID	Internal unique identifier
Plan ID	Internal unique identifier
Policy Number	Unique business-facing policy identifier
Claim Number	Unique business-facing claim identifier
Transaction Reference	Unique payment reference
Document ID	Internal unique identifier

Identifier Requirements

Rule ID	Rule
ID-RUL-001	Policy number must be unique.
ID-RUL-002	Claim number must be unique.
ID-RUL-003	Transaction reference must be unique.

Rule ID	Rule
ID-RUL-004	Business identifiers should be readable and traceable.
ID-RUL-005	Internal identifiers should not replace business identifiers in customer-facing responses.

28. Data Retention and Deactivation Rules

Rule ID	Rule
DRD-001	Users should be deactivated instead of deleted.
DRD-002	Products should be deactivated instead of deleted.
DRD-003	Plans should be deactivated instead of deleted.
DRD-004	Policies should not be hard deleted.
DRD-005	Payments should not be hard deleted.
DRD-006	Claims should not be hard deleted.
DRD-007	Claim status history should not be deleted.
DRD-008	Business records should remain available for audit and reference.

29. Non-Functional Requirements

29.1 Security

Requirement ID	Requirement
NFR-SEC-001	JWT authentication is mandatory.
NFR-SEC-002	Role-based authorization is mandatory.
NFR-SEC-003	Passwords must be stored securely.
NFR-SEC-004	Unauthorized access must be blocked.
NFR-SEC-005	Sensitive information must not be exposed in logs or responses.

29.2 Maintainability

Requirement ID	Requirement
NFR-MNT-001	The system must follow layered architecture.
NFR-MNT-002	DTOs must be used for request and response.
NFR-MNT-003	Business logic must not be placed in controllers.
NFR-MNT-004	Naming should be consistent and meaningful.
NFR-MNT-005	Common response and error structures should be used.

29.3 Reliability

Requirement ID	Requirement
NFR-REL-001	Invalid operations must be handled gracefully.
NFR-REL-002	Raw technical errors must not be exposed to API consumers.
NFR-REL-003	Policy lifecycle rules must be enforced consistently.
NFR-REL-004	Claim lifecycle rules must be enforced consistently.
NFR-REL-005	Duplicate records must be prevented where required.

29.4 Performance

Requirement ID	Requirement
NFR-PER-001	List APIs must support pagination.
NFR-PER-002	List APIs must not return unlimited records.
NFR-PER-003	Search and filter operations should avoid unnecessary large responses.
NFR-PER-004	API responses should remain reasonably fast for moderate datasets.
NFR-PER-005	Maximum page size must be controlled.

29.5 Documentation

Requirement ID	Requirement
NFR-DOC-001	All APIs must be documented in Swagger.
NFR-DOC-002	Security requirements must be visible in Swagger.
NFR-DOC-003	Request and response formats must be clearly documented.
NFR-DOC-004	Error response formats must be documented.
NFR-DOC-005	Pagination, sorting, and filtering inputs must be documented.

30. Acceptance Criteria

Acceptance ID	Acceptance Criteria
AC-001	Customer can register successfully.
AC-002	Public users cannot register as admin or agent.
AC-003	Active users can login successfully.
AC-004	JWT token is generated after successful login.
AC-005	Protected APIs reject requests without valid JWT token.
AC-006	Role-based access restrictions work correctly.
AC-007	Admin can create, update, and deactivate insurance products.
AC-008	Admin can create, update, and deactivate policy plans.
AC-009	Customer can create and update own profile.
AC-010	Customer cannot access another customer's data.
AC-011	Customer can purchase a policy from an active plan.
AC-012	Policy is created with Pending Payment status.
AC-013	Successful required payment activates policy.
AC-014	Failed payment does not activate policy.
AC-015	Customer can raise claim only for own active policy.
AC-016	Claim amount exceeding policy coverage is rejected.
AC-017	Agent can review and recommend claim decision.
AC-018	Agent cannot approve or reject claim finally.

Acceptance ID	Acceptance Criteria
AC-019	Admin can approve or reject claim finally.
AC-020	Approved or rejected claims cannot be modified.
AC-021	Claim status history is recorded.
AC-022	All major errors return structured error responses.
AC-023	Swagger displays all API groups clearly.
AC-024	Logs are generated for major business events.
AC-025	Pagination works for all list APIs.
AC-026	List APIs apply default pagination when pagination inputs are not provided.
AC-027	List APIs reject invalid pagination inputs.
AC-028	Paginated responses include pagination metadata.
AC-029	Sorting and filtering work with pagination where applicable.
AC-030	Entities are not directly exposed in API responses.

31. Ambiguity Removal Checklist

Possible Confusion	Final Requirement
Can public users register as admin?	No
Can public users register as agent?	No
Who can self-register?	Only customers
Who creates agents?	Admin
Can customer pass customer ID while purchasing own policy?	No, customer is identified through authenticated account
Can admin or agent issue policy for customer?	Yes
Is real payment gateway required?	No
Is payment simulated?	Yes
What activates a policy?	Successful required premium payment
Can failed payment activate policy?	No
Can claim be raised before payment?	No

Possible Confusion	Final Requirement
Can claim be raised on expired policy?	No
Can claim be raised on cancelled policy?	No
Can customer view all claims?	No, only own claims
Can agent make final claim decision?	No
Who approves or rejects claims finally?	Admin
Is actual document upload required?	No, document reference is enough
Are products and plans hard deleted?	No, they are deactivated
Is claim status history required?	Yes
Is JWT required?	Yes
Is Swagger required?	Yes
Are DTOs required?	Yes
Is logging required?	Yes
Is pagination required?	Yes, for all list APIs
What happens if pagination inputs are missing?	Default pagination is applied
Can list APIs return unlimited records?	No
Should invalid pagination inputs be accepted?	No

32. Final Expected Deliverable

The final project should be a working Spring Boot REST API backend system containing:

1. Authentication and authorization.
2. JWT token-based security.
3. Role-based access control.
4. User management.
5. Customer profile management.
6. Insurance product management.
7. Policy plan management.
8. Policy purchase and issuance.
9. Premium payment tracking.
10. Claim submission.
11. Claim review and recommendation.
12. Final claim approval or rejection.
13. Claim status history.

14. DTO-based request and response handling.
 15. Centralized exception handling.
 16. Swagger/OpenAPI documentation.
 17. Structured logging.
 18. Pagination, sorting, and filtering.
 19. Clean layered architecture.
 20. Proper entity relationship mapping.
-

33. One-Line Project Summary

Build a secure REST API-based Insurance Policy and Claim Management System where customers purchase policies and raise claims, agents review and recommend claim decisions, and admins manage products, plans, users, and final claim approvals using JWT-based role-based access control.